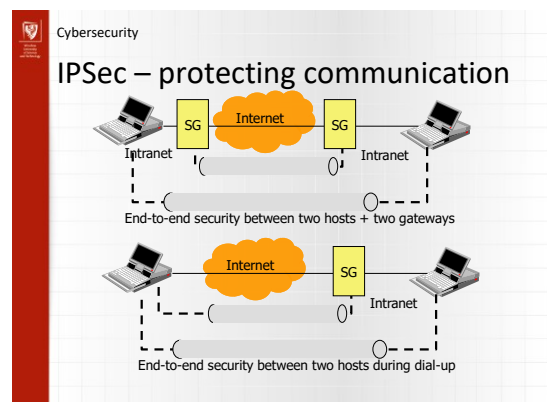
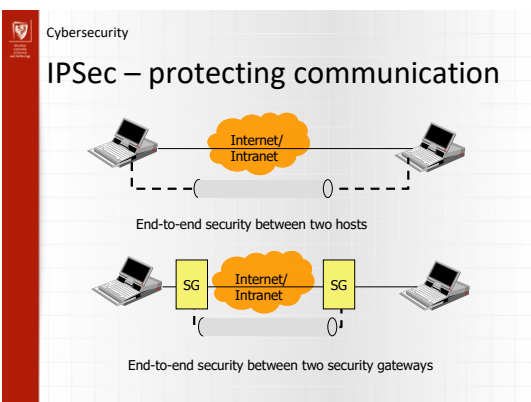
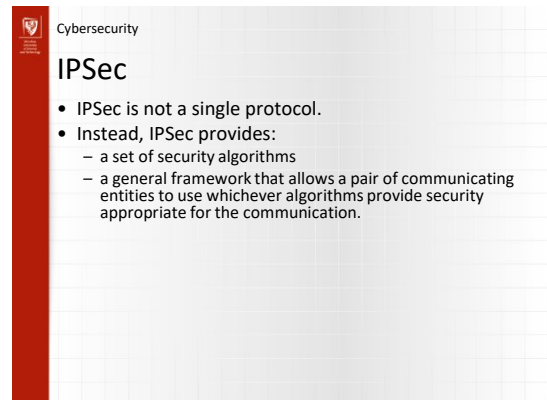
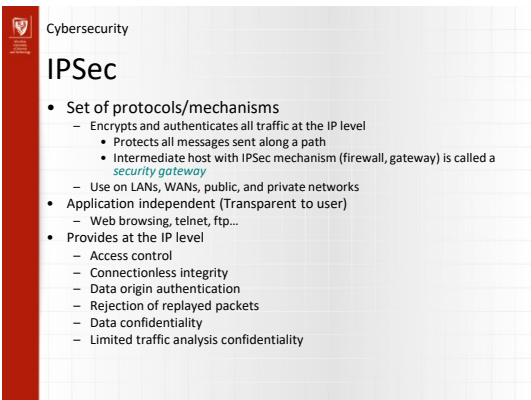
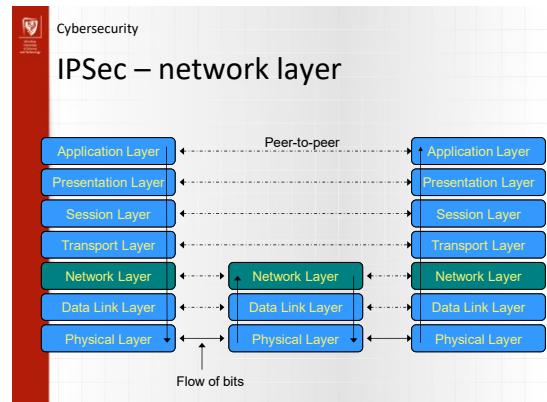
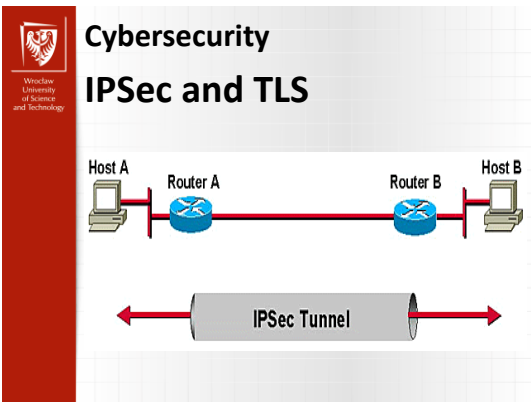




Cybersecurity

IPSec - protocols

- Authentication header (AH) protocol
 - Message integrity
 - Origin authentication
 - Anti-replay services
- Encapsulating security payload (ESP) protocol
 - Confidentiality
 - Message integrity
 - Origin authentication (limited)
 - Anti-replay services
- Internet Key Exchange (IKE)
 - Exchanging keys between entities that need to communicate over the Internet
 - What authentication methods to use, how long to use the keys, etc.

Cybersecurity

IPSec - Security Association (SA)

- Unidirectional relationship between peers (a sender and a receiver)
- Specifies the security services provided to the traffic carried on the SA
 - Security enhancements to a channel along a path
- Identified by three parameters:
 - IP Destination Address
 - Security Protocol Identifier
 - Specifies whether AH or ESP is being used
 - Security Parameters Index (SPI)
 - Specifies the security parameters associated with the SA

Cybersecurity

IPSec - Security Association (SA)

- Each SA uses AH or ESP (not both)
 - If both required two SAs are created
- Multiple security associations may be used to provide required security services
 - A sequence of security associations is called *SA bundle*
 - Example: We can have an AH protocol followed by ESP or vice versa

Cybersecurity

IPSec - Security Association Database

- IP needs to know the SAs that exist in order to provide security services
- IPsec SAs always come in pairs: inbound and outbound
- SAD is keyed by SPI (for unicast packets)
- SAs are typically created by IKE but they may also be configured manually or by other software, e.g. to create fixed VPN tunnels
- Security Association Database (SAD)
 - Keeps track of the sequence number
 - AH information (keys, algorithms, lifetimes)
 - ESP information (keys, IVs, algorithms, lifetimes)
 - Lifetime of the SA
 - Protocol mode
 - MTU

Cybersecurity

IPSec - Security Policy Database

- Specifies the static security policy
- Multi-homed nodes have a separate SPD for each network interface (in practice, they can be stored on one database) (multihomed = node with multiple network interfaces)
- Policy maps inbound and outbound packets to actions
 - SPD = linearly ordered list of policies
 - Policy = selectors + action
 - The first policy with matching selectors applies to each packet
- Policy selector is a 5-tuple:
 - Local and remote IP address
 - Transport protocol (TCP, UDP, ICMP)
 - Source and destination ports
- Actions: BYPASS (allow), DISCARD (block), or PROTECT
 - PROTECT specifies also the session protocol and algorithms
 - Packet is mapped to a suitable IPsec security association (SA)
 - If the SA does not exist, IKE is triggered to create them
 - SPD stores pointers to previously created SAs
- Policies at peer nodes must match if they are to communicate

Cybersecurity

IPSec – Gateway SPD/SAD

SPD of gateway A, interface 2

Protocol	Local IP	Port	Remote IP	Port	Action	Comment
UDP	2.3.4.5	500	4.5.6.7	500	BYPASS	IKE
*	1.2.3.0/24	*	5.6.7.0/24	*	ESP tunnel tp 4.5.6.7	Protect VPN traffic
*	*	*	*	*	BYPASS	All other peers

Pointers to created associations

SAD of gateway A

SPI	SPD selector values	Protocol	Algorithms, keys, algorithm state
spl1	TCP, 1.2.3.0/24, 5.6.7.0/24	ESP tunnel from 4.5.6.7	...
spl2	...	ESP tunnel to 4.5.6.7	...

Cybersecurity

IPSec – Host SPD

- SPD for host 1.2.3.101 in intranet 1.2.3.0/24, connecting to server 1.2.4.10 in network 1.2.4.0/24 (DMZ) and to the Internet

Protocol	Local IP	Port	Remote IP	Port	Action	Comment
UDP	1.2.3.101	500	*	500	BYPASS	IKE
ICMP	1.2.3.101	*	*	*	BYPASS	Error messages
*	1.2.3.101	*	1.2.3.0/24	*	PROTECT: ESP in transport-mode	Encrypt intranet traffic
TCP	1.2.3.101	*	1.2.4.10	80	PROTECT: ESP in transport-mode	Encrypt to server
TCP	1.2.3.101	≥1024	1.2.4.10	443	BYPASS	Allow TLS, no double encryption
*	1.2.3.101	*	1.2.4.0/24	*	DISCARD	Others in DMZ
*	1.2.3.101	*	*	*	BYPASS	Internet

- Note that the other endpoint (other intranet hosts and 1.2.4.10) must have an IPSec policy that specifies the same protection for the same packets

Cybersecurity

IPSec – Outbound processing

- Processing outbound packets in IPSec:
 - For each outbound packet, IPSec finds the first matching policy in the security policy database (SPD)
 - If the policy requires protection, IPSec maps the packet to the right security association (SA) in the SA database (SAD)
 - If no SA exists, IPSec invokes the IKE service (running in user space) to create a new SA pair
 - While waiting for the IPSec SA, at most one outbound packet (often TCP SYN) is buffered in the kernel
 - When the SA exists, the packet is secured and a MAC added

Cybersecurity

IPSec – Inbound processing

- Processing inbound IPSec packets:
 - IPsec looks up the inbound SA in SAD based on the SPI
 - IPsec processes the packet with the SA, i.e. verifies the MAC and decrypts
 - IPsec compares the packet with the selector values that were used when creating this SAD entry. For tunnel-mode packets, the comparison is done with the inner IP header
- Processing of inbound non-IPsec packets:
 - IPsec finds the first matching policy in the SPD and checks that the action is BYPASS
 - If the action is not BYPASS, the packet is dropped
- In Windows, it is possible to allow the first inbound packet (often TCP SYN) to bypass IPSec. The outbound response will trigger IKE
 - Helps in gradual deployment of host-to-host IPSec

Cybersecurity

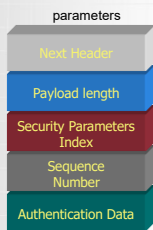
IPSec – Modes of Operation

- Two modes
 - Transport mode
 - Host-to-host security
 - Encapsulates IP packet data area
 - IP Header is not protected
 - Protection is provided for the upper layers
 - Usually used in host-to-host communications
 - Tunnel mode
 - Typically used for tunnels between security gateways to create a VPN
 - Encapsulates entire IP packet in an IPSec envelope
 - Helps against traffic analysis
 - The original IP packet is untouched in the Internet

Cybersecurity

IPSec – Authentication Header (AH)

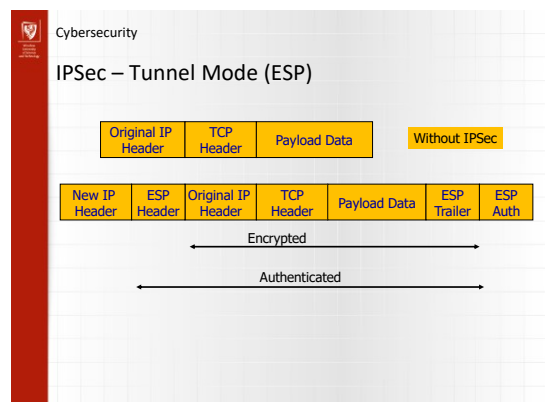
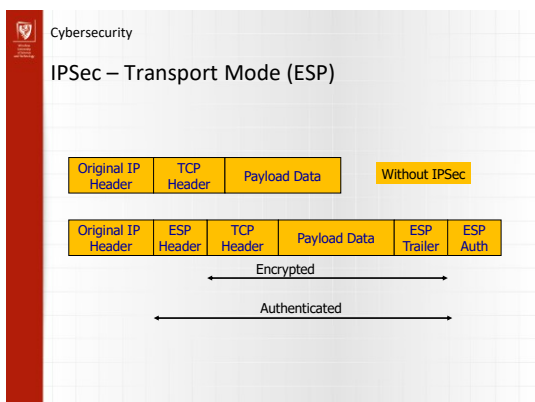
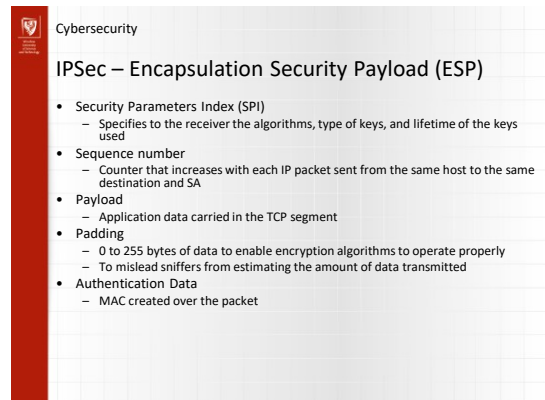
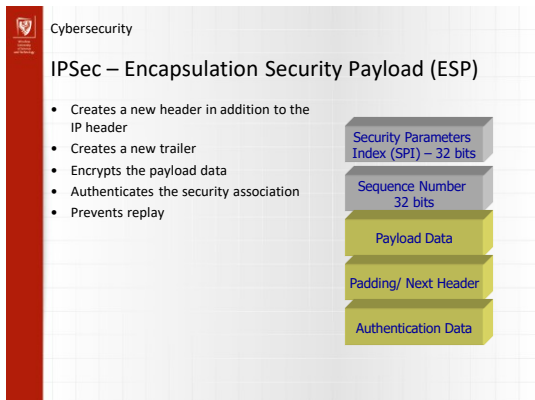
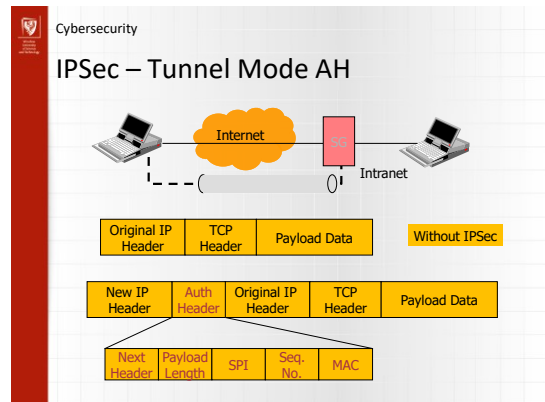
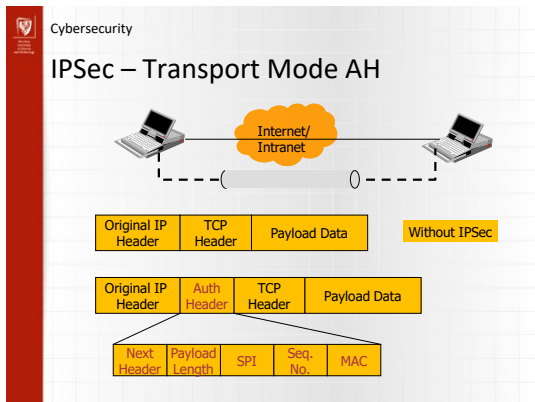
- Next header
 - Identifies what protocol header follows
- Payload length
 - Indicates the number of 32-bit words in the authentication header
- Security Parameters Index
 - Specifies to the receiver the algorithms, type of keys, and lifetime of the keys used
- Sequence number
 - Counter that increases with each IP packet sent from the same host to the same destination and SA
- Authentication Data



Cybersecurity

IPSec – Preventing Replay

- Using 32 bit sequence numbers helps detect replay of IP packets
- The sender initializes a sequence number for every SA
 - Each succeeding IP packet within a SA increments the sequence number
- Receiver implements a window size of W to keep track of authenticated packets
- Receiver checks the MAC to see if the packet is authentic



Cybersecurity

IPSec – AH vs ESP

- Two header types...
 - Authentication header (AH)
 - Provides integrity only
 - Encapsulating security payload (ESP)
 - Provides encryption and/or integrity
- Both provide cryptographic protection of everything beyond the IP headers
 - AH additionally provides integrity protection of some fields of the IP header

Cybersecurity

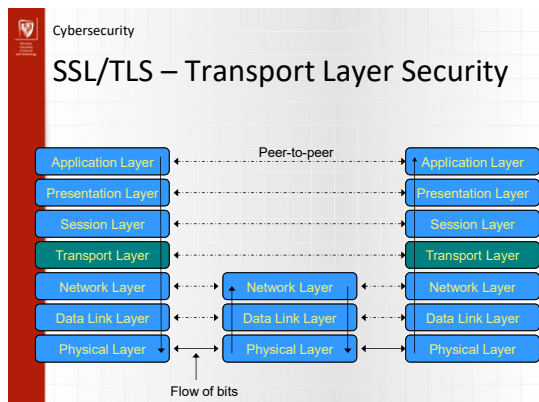
IPSec – AH vs ESP

- AH provides integrity protection on header
 - But some fields change *en route*!
- Immutable fields included in the integrity check
- Mutable but predictable fields are also included in the integrity check
 - The *final* value of the field is used

Cybersecurity

IPSec – AH vs ESP

- ESP can already provide encryption and/or authentication
- So why do we need AH?
 - AH also protects the IP header
 - Firewalls need some high-level data to be unencrypted
- None of these are compelling...



Cybersecurity

SSL/TLS – Transport Layer Security

- SSL/TLS is the protocol used for most secure transactions over the Internet
- For example, if you want to buy a book at amazon.com...
 - You want to be sure you are dealing with Amazon (**authentication**)
 - Your credit card information must be protected in transit (**confidentiality** and/or **integrity**)
 - As long as you have money, Amazon doesn't care who you are (authentication need not be mutual)

Cybersecurity

SSL/TLS – Transport Layer Security

- Developed by Netscape to provide security in WWW browsers and servers
- SSL is the basis for the Internet standard protocol – Transport Layer Security (TLS) protocol (compatible with SSLv3)
 - now it is not secure
 - In 2014, SSL 3.0 was found to be vulnerable to the POODLE attack that affects all block ciphers in SSL; RC4, the only non-block cipher supported by SSL 3.0, is also feasibly broken as used in SSL 3.0.
 - SSL 2.0 was prohibited in 2011 by RFC 6176, and SSL 3.0 was also later prohibited in June 2015 by RFC 7568.
 - secure TLS 1.2 and TLS 1.3

Cybersecurity

SSL/TLS – Transport Layer Security

- Key idea: *Connections and Sessions*
 - A session is an association between two peers
 - A connection is the set of mechanisms used to transport data in a session
- Each party keeps session information
 - Session identifier (unique)
 - The peer's X.509(v3) certificate
 - Compression method used to reduce volume of data
 - Cipher specification (parameters for cipher and MAC)
 - Master secret of 48 bits
- Connection information
 - Random data for the server & client
 - Server and client keys (used for encryption)
 - Server and client MAC key
 - Initialization vector for the cipher, if needed
 - Server and client sequence numbers
- Provides a set of supported cryptographic mechanisms that are setup during negotiation (handshake protocol)

Cybersecurity

SSL/TLS – Idea of protocol

```

sequenceDiagram
    participant Alice
    participant Bob
    Note over Alice: I'd like to talk to you securely
    Alice->>Bob: Here's my certificate
    Bob-->>Alice: {K_AB} Bob
    Alice-->>Bob: protected HTTP
  
```

- Is Alice sure she's talking to Bob?
- Is Bob sure he's talking to Alice?

Cybersecurity

SSL/TLS – simplified protocol

```

sequenceDiagram
    participant Alice
    participant Bob
    Alice->>Bob: Can we talk?, cipher list, R_A
    Bob-->>Alice: certificate, cipher, R_B
    Alice-->>Bob: {S}_Bob, E(h(msgs, CLNT, K), K)
    Bob-->>Alice: h(msgs, SRVR, K)
    Alice-->>Bob: Data protected with key K
  
```

- S is **pre-master secret**
- $K = h(S, R_A, R_B)$
- msgs = all previous messages
- CLNT and SRVR are constants

Cybersecurity

SSL/TLS – keys

- 6 “keys” derived from $K = \text{hash}(S, R_A, R_B)$
 - 2 encryption keys: send and receive
 - 2 integrity keys: send and receive
 - 2 IVs: send and receive
 - Why different keys in each direction?
- Q: Why is $h(\text{msgs}, \text{CLNT}, K)$ encrypted (and integrity protected)?
- A: It adds no security...

Cybersecurity

SSL/TLS – authentication

- Alice authenticates Bob, not vice-versa
 - How does client authenticate server?
 - Why does server not authenticate client?
- Mutual authentication is possible: Bob sends **certificate request** in message 2
 - This requires client to have certificate
 - If server wants to authenticate client, server could instead require (encrypted) password

Cybersecurity

SSL/TLS – MiM attack

```

sequenceDiagram
    participant Alice
    participant Bob
    participant Trudy
    Alice->>Bob: R_A
    Bob-->>Alice: certificate_B, R_B
    Alice-->>Bob: {S}_Bob, E(h(msgs, CLNT, K), K)
    Bob-->>Trudy: {S}_Trudy, E(h(X_1, K_1))
    Trudy-->>Bob: h(Y_1, K_1)
    Bob-->>Alice: E(data, K_1)
    Alice->>Trudy: R_A
    Trudy-->>Bob: certificate_B, R_B
    Bob-->>Trudy: {S}_Bob, E(h(X_2, K_2))
    Trudy-->>Bob: h(Y_2, K_2)
    Bob-->>Trudy: E(data, K_2)
  
```

- Q: What prevents this MiM attack?
- A: Bob's certificate must be signed by a certificate authority (such as Verisign)
- What does Web browser do if sig. not valid?
- What does user do if signature is not valid?

Cybersecurity

SSL/TLS – security

- Only works if client trusts server's public key!
- Solution: Authenticate using a common third party both sides can trust
- And thus, the CA (Certificate Authority) model was born

Cybersecurity

SSL/TLS – Certificates

Document including:

- The server's public key
- The server's name (usually: DNS name)
- Expiration date
- Digitally signed by CA (using its private key)
- Server (Bob) has to convince (\$\$\$\$) CA that:
 - the public-key is really his
 - he is who he says he is

Cybersecurity

SSL/TLS – Certificates

- Alice trusts the CA (has the CA's public key)
- Bob has a Certificate (signed by the CA)
- Bob presents a certificate to Alice
- Alice verifies the certificate (with CA's public key)
- Alice and Bob use information from the certificate to set up an authenticated session

Cybersecurity

SSL/TLS – Certificates

- Problem –
 - As a CA, you have to verify each certificate request and stake your reputation on it
- Solution –
 - More CAs were created
 - New, more thorough validation standards added (EV = Extended Validation)
 - CAs delegated further. Most OS and browsers will trust 10-100 root CAs out of the box, and 100-1000 CAs implicitly

Cybersecurity

SSL/TLS – Certificates

Each and every CA your system trusts can be evil (or at least – incompetent) and **compromise everything**

- CAs can be fooled into signing bad certificates
- Some CAs were compromised (DigiNotar)
- Some CAs are “evil”/forced into being evil (TurkSign, CNNIC)
- Even worse – even when shown to be bad, some CAs were not removed (Comodo) because they were “too big to fail”.

Cybersecurity

SSL/TLS – Certificates

- Certificate Pinning –
 - Storing a digest of the certificate inside the browser/application, and validating the trusted certificate yourself
- Certificate transparency –
 - CA publishes a list of all the certificates it has ever signed
 - Only Certificates on that list are trusted
 - Anyone can audit the published list

Cybersecurity

SSL/TLS – session vs connections

- **Session** is established as shown on previous slides
 - Designed for use with HTTP 1.0
- HTTP usually opens multiple simultaneous (parallel) **connections**
- Session establishment is costly
 - Due to public key operations
- SSL/TLS has an efficient protocol for opening new connections given an existing session

Cybersecurity

SSL/TLS – connections

- Assuming **session** exists
- So S is already known to Alice and Bob
- Both sides must remember session-ID
- Again, $K = h(S, R_A, R_B)$
 - No public key operations! (relies on known S)

Cybersecurity

SSL/TLS – architecture

- Provides a basis for
- Secure communication
- Confidentiality +
- Message authenticity

Figure 7.2 SSL Protocol Stack

Cybersecurity

Record Protocol Operation

Message type, version, length of block

Cybersecurity

Handshake Protocol

- The most complex part of SSL/TLS
- Allows the server and client to authenticate each other
 - Based on interchange cryptosystem (e.g., RSA)
- Negotiate encryption, MAC algorithm and cryptographic keys
 - Four rounds
- Used before any application data are transmitted

Cybersecurity

SSL/TLS – other protocols

- Change Cipher Spec Protocol
 - A single byte is exchanged
 - After new cipher parameters have been negotiated (renegotiated)
- Alert Protocol
 - Signals an unusual condition
 - Closure alert : sender will not send anymore
 - Error alert: fatal error results in disconnect

- **IPSec**
 - Lives at the network layer (part of the OS)
 - Has encryption, integrity, authentication, etc.
 - Is overly complex
- **SSL/TLS**
 - Lives at socket layer (part of user space)
 - Has encryption, integrity, authentication, etc.
 - Has a simpler specification

UNIVERSITY OF CAMBRIDGE

- IPsec implementation
 - Requires changes to OS, but no changes to applications
- SSL/TLS implementation
 - Requires changes to applications, but no changes to OS
- SSL/TLS built into Web application
- IPsec used in VPN applications (secure tunnel)



Security in Computer Network